Business Decision Memo

Florence Inc. security assessment

Decision requested

Management is being asked to approve the mitigation plan, fund and schedule replacement of the two unsupported payment servers, and confirm how the eight risks that remain High will be handled. The retest closed all three Critical risks.

1. What the assessment found

The assessment reviewed 12 security controls across 13 systems and data stores. It produced 33 results: 18 failed and 15 passed. Every check had enough evidence to reach a decision.

The 18 failures were made up of 4 Critical, 10 High, and 4 Medium findings. The most serious issues were an administrative remote-access port exposed directly to the internet, privileged accounts without enforced multi-factor authentication, and customer documents stored in a publicly readable cloud location.

2. Which risks matter most

Risk scores combine likelihood and impact, each rated from 1 to 5. Scores of 1–4 are Low, 5–9 Medium, 10–16 High, and 17–25 Critical.

Risk	What could happen	Evidence	Score / Rating	Action
RISK-REMOTE-ACCESS-01	An attacker could reach an administrative service exposed to the internet.	The firewall rule allow-rdp-any exposes port 3389 to 0.0.0.0/0.	25 Critical	Mitigate Security Lead Due 2026-10-09
RISK-CLOUD-EXPOSURE-01	Sensitive customer information could be accessed or downloaded from public storage.	cust-docs-prod is public and contains customer PII and identity documents.	20 Critical	Mitigate Data Protection Officer Due 2026-10-09
RISK-MFA-01	A privileged account could be taken over using only its password.	3 of 12 privileged accounts do not have MFA properly enforced or enrolled.	20 Critical	Mitigate IT Operations Manager Due 2026-10-09
RISK-ENDPOINT-02	Malware could run on remote devices without effective protection.	3 of 30 remote devices lack active, current protection. Two have no installed agent and one has outdated definitions.	16 High	Mitigate IT Operations Manager Due 2026-11-01
RISK-CLOUD-EXPOSURE-02	Sensitive financial information could be accessed or	finance-reports is public and contains financial records.	15 High	Mitigate Head of Finance Due 2026-11-01

	downloaded from public storage.			

3. Potential impact

A simulation of 10,000 possible years was run for the six largest risks. It uses assumed event frequencies and loss sizes for Florence, so it is meant to show the possible scale and direction of loss, not to predict what will happen. Management's annual loss threshold is $250,000.

Measure	Before remediation	After retest
Expected loss in a year	$1,005,604	$196,978
Typical year (median)	$518,979	$0
Bad year (1 in 10)	$2,615,105	$564,716
Chance of losing more than $250,000	64.2%	19.8%

4. What the retest confirmed

One week later, the checks were repeated using updated evidence. Ten of the 18 previously failed risks are now closed. Eight remain open.

Risk	Issue fixed	Before → After
RISK-REMOTE-ACCESS-01	Administrative ports were open to the internet.	Critical → Low
RISK-CLOUD-EXPOSURE-01	Sensitive data storage was publicly accessible.	Critical → Low
RISK-MFA-01	Privileged accounts could sign in with a password alone.	Critical → Low
RISK-CLOUD-EXPOSURE-02	Sensitive data storage was publicly accessible.	High → Low
RISK-ENC-REST-01	Sensitive data stores lacked adequate encryption or customer-managed keys.	High → Low
RISK-ENC-TRANSIT-01	Sensitive flows used cleartext or outdated TLS.	High → Low
RISK-INACTIVE-ACCT-01	Former staff accounts remained enabled.	High → Low
RISK-ENC-REST-02	Sensitive data stores lacked adequate encryption or customer-managed keys.	High → Low
RISK-BACKUP-01	Backups were missing, stale, or not protected from tampering.	High → Low
RISK-BACKUP-05	Backups were missing, stale, or not protected from tampering.	Medium → Low

5. Risks that remain after the retest

There are no Critical risks left open. Eight High risks remain and should be treated as mitigation items unless management formally chooses another treatment.

Risk	Remaining gap	Rating	Action / Owner / Due
RISK-ENDPOINT-02	Remote endpoints lack active, current protection.	High	Mitigate, low effort IT Operations Manager 2026-11-01
RISK-ENC-TRANSIT-03	Payment gateway uses cleartext or outdated TLS.	High	Mitigate, medium effort IT Operations Manager 2026-11-01
RISK-EXCESS-PRIV-01	Users have permissions they do not use or have approval for.	High	Mitigate, medium effort IT Operations Manager 2026-11-01
RISK-PASSWORD-01	Local password policy is below the required baseline.	High	Mitigate, low effort IT Operations Manager 2026-11-01
RISK-VULN-SW-02	Payment gateway runs unsupported or severely vulnerable software.	High	Mitigate, high effort IT Operations Manager 2026-11-01
RISK-VULN-SW-03	Reconciliation server runs unsupported or severely vulnerable software.	High	Mitigate, high effort IT Operations Manager 2026-11-01
RISK-LOGGING-01	Required security log sources are silent or auditing is disabled.	High	Mitigate, low effort Security Lead 2026-11-01
RISK-BACKUP-04	Reconciliation server backups are missing, stale, or not protected from tampering.	High	Mitigate, medium effort IT Operations Manager 2026-11-01

6. What management needs to decide

1. Approve the mitigation plan. Critical items have a seven-day target, High items a 30-day target, and Medium items a 90-day target. Critical and High items require executive approval.

2. Fund and schedule the high-effort work. The payment gateway server and reconciliation server need replacement because unsupported software cannot be fixed through configuration alone.

3. Confirm how the eight remaining High risks will be treated. The default approach is to mitigate them by the target dates. If a risk remains High after retesting, management may consider partial transfer, such as reviewing cyber insurance, while remediation continues.

4. Do not treat any current risk as accepted. If acceptance becomes necessary, it should be limited to 90 days, supported by a compensating control, and approved in writing.

5. Reassess when circumstances change. Review the position if a control that passed the retest fails again, a new critical vulnerability affects software in the inventory, Florence adds a payment product, partner connection, or sensitive data store, or a security incident occurs. A quarterly review should also be completed.

7. Basis and limits

Florence Inc. is a fictional company and the evidence used for this assessment is simulated. Likelihood ratings represent the threat associated with each gap, while impact reflects the importance of the affected system. The loss figures are scenario assumptions, not measured losses.

The references to NIST CSF 2.0 and ISO/IEC 27001:2022 are illustrative and do not represent certification. This document reflects what the available evidence supports. Management remains responsible for the final decision.